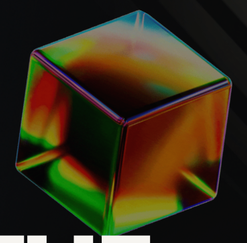
OCT 15 2026



WHEN HTTP 402 MEETS THE BLOCKCHAIN: RISKS ON EMERGING X402 PAYMENTS

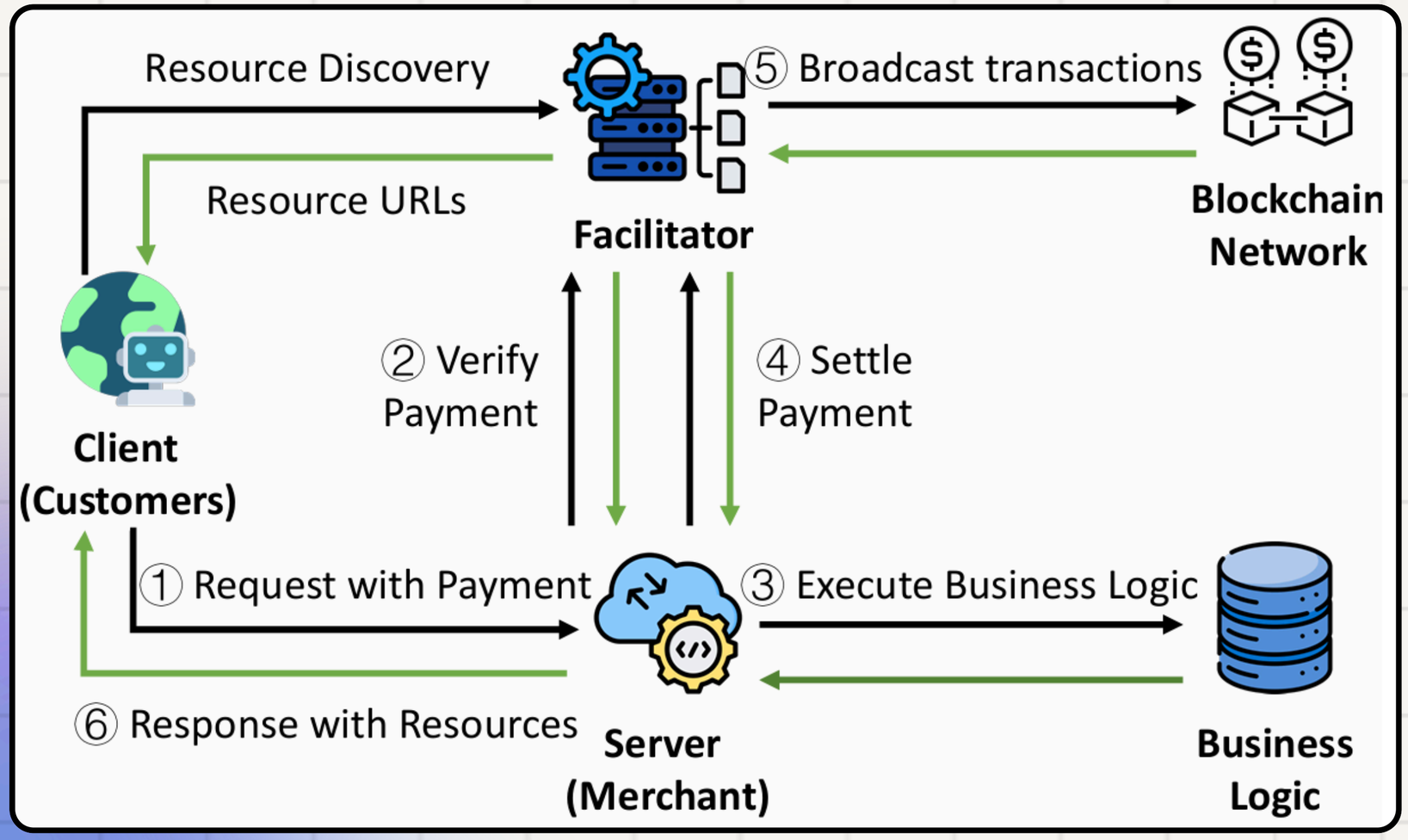
AI AGENTS ARE STARTING TO PAY FOR ONLINE SERVICES ON THEIR OWN. HOW SAFE IS THE INFRASTRUCTURE BEHIND THESE PAYMENTS?

150M+
on-chain transactions

$40M+
cumulative payment volume

5 majors
Coinbase, Cloudflare, AWS, Circle, Google

HOW X402 WORKS, AND WHERE THE RISK SITS



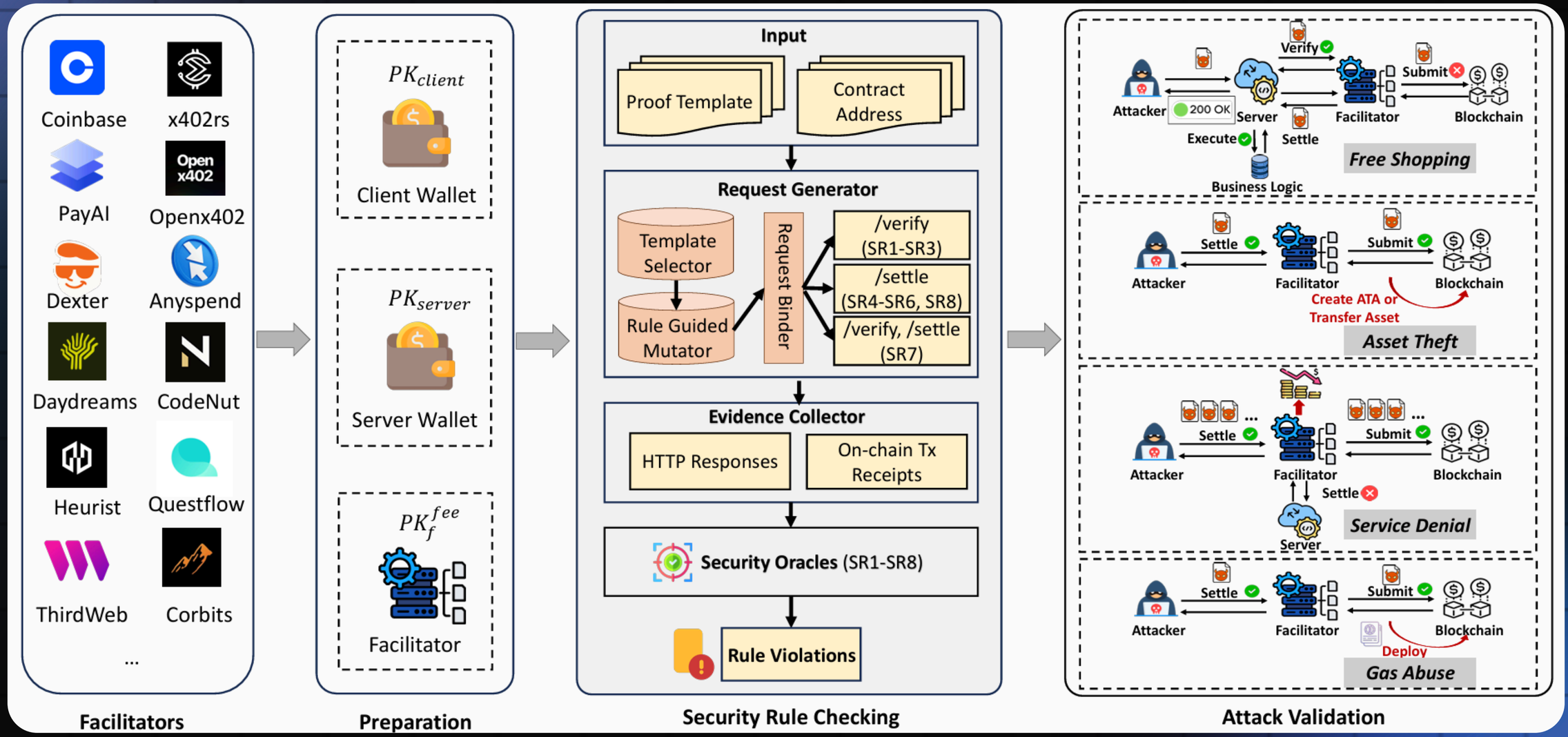
01 Agent requests a paid resource; the server replies “payment required” (HTTP 402)

02 A facilitator verifies the signed payment and settles it on-chain

03 One facilitator serves many merchants, so one flaw spreads

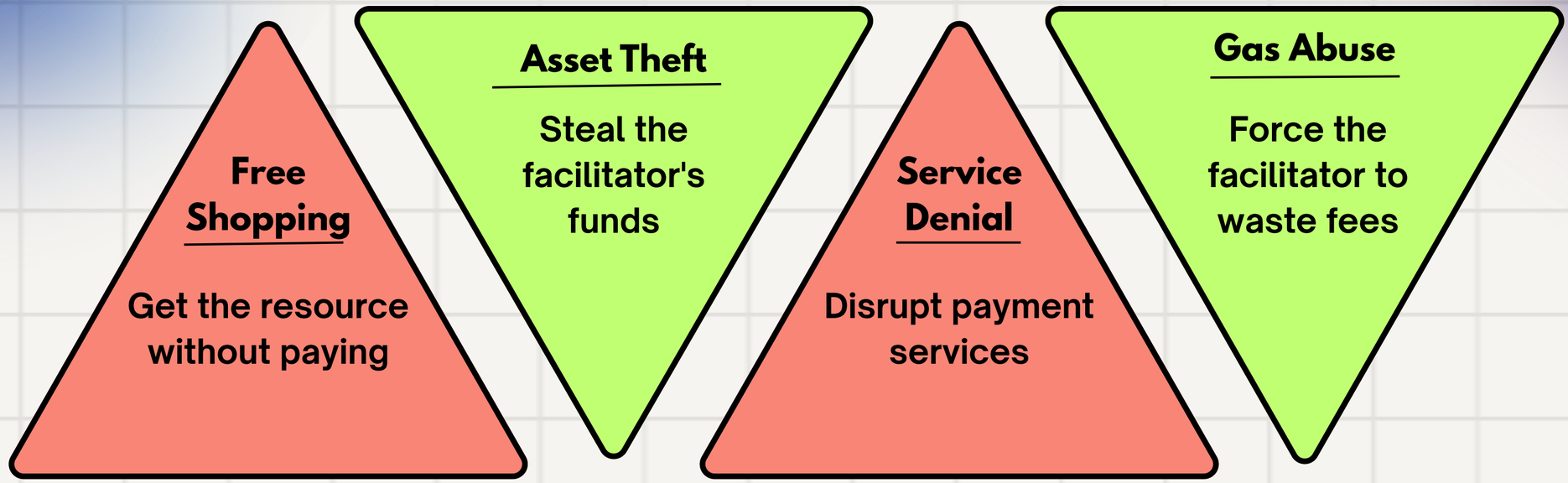
→Irreversible payments + facilitator-paid fees = verification must be strict

METHOD: RULE-GUIDED BLACK-BOX TESTING



8 SECURITY RULES → TAMPERED PAYMENTS SENT TO 15 REAL FACILITATORS → FOUR ATTACK CLASSES VALIDATED

RESULTS: 15 OUT OF 15 HAD FLAWS

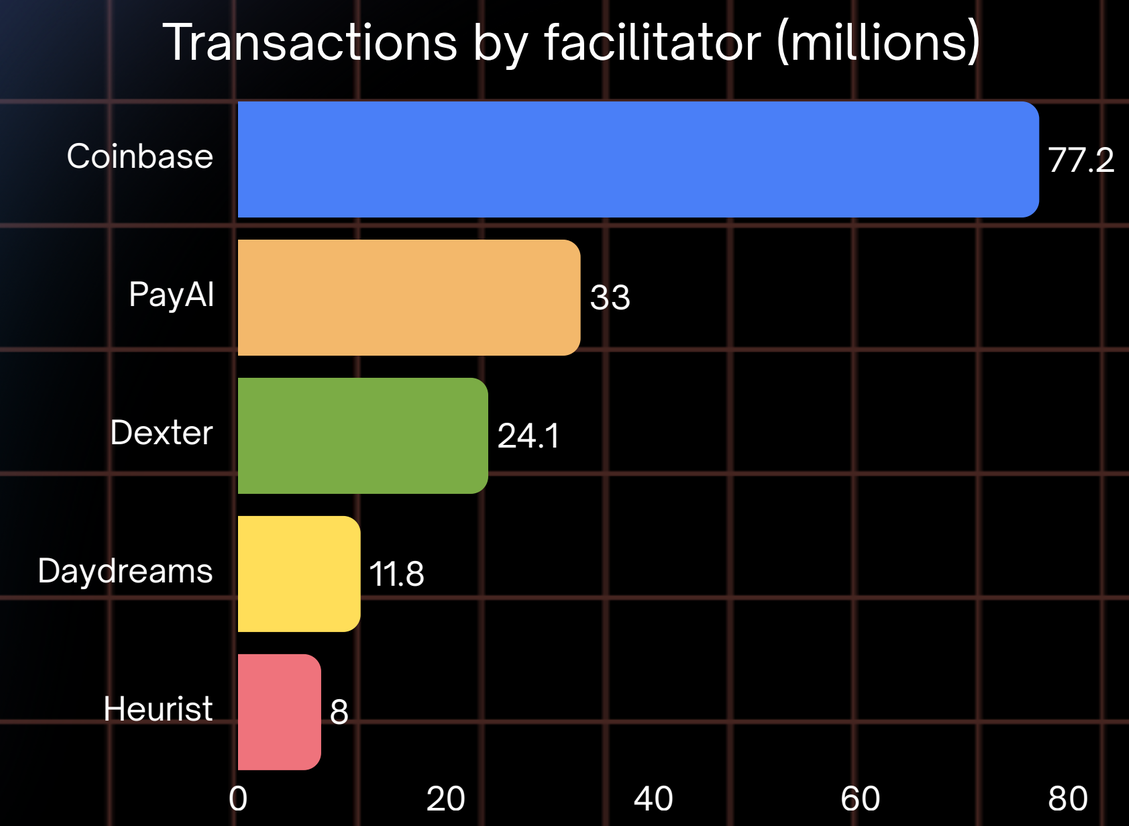


15/15
facilitators broke at least one rule

31
vulnerabilities found (49 rule violations)

$202K+ ALREADY SPENT ON GAS AND FEES · VENDORS, INCL. COINBASE, BEGAN FIXES

TAKEAWAY: CONCENTRATED RISK, CLEAR FIXES



Coinbase alone: 77M transactions. Over 93% of servers rely on a single facilitator.

Recommended fixes

01 **Tie verification to settlement**

02 **Treat client input as hostile**

03 **Binding constraint**

04 **Merchants: release goods only after payment settles.**

As AI agents handle money, payment infrastructure needs bank-level security.